



이제부터 이 계정은 제깍니다.
(CSRF, XSS로 웹 공격해보기)

AUSG 7th.

송승호

Motivation

in 2022..

```
1  const express = require('express');
2  const session = require('express-session');
3  const cookieParser = require('cookie-parser');
4  const csrf = require('csurf');
5  const helmet = require('helmet');
6
7  const app = express();
8  const csrfProtection = csrf({ cookie: true }); // 쿠키에 csrf Secret을 저장. 만일 세션에 저장하고 싶다면 { cookie: false }로
9
10 app.use(cookieParser(process.env.COOKIE_SECRET));
11 app.use(session(sessionOption));
12 app.use(helmet());
13
14 /* 쿠키파서나 익스프레스-세션 미들웨어보다 아래에 위치해야 한다. 그리고 csrfProtection 미들웨어를 라우터에 장착 */
15
16 app.get('/purchase', csrfProtection, (req, res) => {
17   // 만일 /purchase 페이지로 접속(get) 하면 req.csrfToken()를 실행하여 템플릿 엔진(pug, nunjucks, ejs)에 csrf 토큰을 생성해서 저장 전달
18   res.render('index', { csrfToken: req.csrfToken() });
19 });
20
21 app.post('/purchase', csrfProtection, (req, res) => {
22   // /purchase 페이지에서 폼 submit이 오면(post) 폼 태그 안에 있던 csrf 토큰 값을 csrfProtection 미들웨어에서 검증하고 next()
23   res.send(req.body.text);
24 });
```

Motivation

in 2022..

아..그냥 보안 관련해서 잘 막아주는
툴인가보다

Motivation in 2022..

CSRF

사이트 간 요청 위조

문서 토론

위키백과, 우리 모두의 백과사전.

사이트 간 요청 위조(또는 **크로스 사이트 요청 위조**, **영어**: Cross-site request forgery, **CSRF**, **XSRF**)는 **웹사이트 취약점 공격**의 한 형태로, 공격자가 의도한 행위(수정, 삭제, 등록 등)를 특정 웹사이트에 요청하게 하는 공격을 말한다.

유명 경매 사이트인 **옥션**에서 발생한 개인정보 유출 사건에서 사용된 공격 방식 중 하나다. **사이트 간 스크립팅**(XSS)을 이용한 공격이 사용자가 특정 웹사이트를 사용하는 점을 노린 것이라면, 사이트간 요청 위조는 상태를 노린 것이다. 일단 사용자가 웹사이트에 **로그인**한 상태에서 사이트간 요청 위조 공격 코드가 삽입된 페이지를 방문하면, 공격 명령이 믿을 수 있는 사용자로부터 발송된 것으로 판단하게 되어 공격에 노출된다.

공격 과정 [편집]

1. 이용자는 웹사이트에 로그인하여 정상적인 쿠키를 발급받는다
2. 공격자는 다음과 같은 링크를 이메일이나 게시판 등의 경로로 통해 이용자에게 전달한다.
`http://www.geocities.com/attacker`
3. 공격용 **HTML** 페이지는 다음과 같은 이미지가 담겨 있다.

```
[1]</sup>)은 **웹 애플리케이션**에서 많이 나타나는 취약점의 하나로 **웹사이트** 관리자가 아닌 이가 **웹 페이지**에 악성 **스크립트**를 삽입할 수 있는 취약점이다. 이 취약점이 CSS가 아닌 이유는 **웹 기술**인 CSS와 헷갈릴 수 있어서다. 주로 여러 사용자가 보게 되는 **전자 게시판**에 악성 스크립트가 담긴 글을 올리려는 형태로 이루어진다. 이 취약점은 웹 애플리케이션이 사용자로부터 입력 받은 값을 제대로 검사하지 않고 사용할 경우 나타난다. 이 취약점으로 해커가 사용자의 정보(쿠키, 세션 등)를 탈취하거나, 자원으로 비정상적인 기능을 수행하게 할 수 있다. 주로 다른 웹사이트와 정보를 교환하는 식으로 작동하므로 사이트 간 스크립팅이라고 한다.<sup>[1]</sup>

### 공격 유형 [ 편집 ]

크로스 사이트 스크립팅(XSS)의 공격 유형은 표준화로 정해져 있지 않지만, 전문가들은 크로스 사이트 스크립팅의 유형을 구분한다. **비 지속적인 XSS**와 **지속적인 XSS**로 구분한다. 그리고 소스코드 추가로 발생되는 **DOM 기반 XSS** 등 유형으로 구분한다.

### 비 지속적인 (Non-persistent) 기법 [ 편집 ]

**비 지속적인 (Non-persistent)** 크로스 사이트 스크립팅 취약점은 **반사 (Reflected)** XSS라고도 불리며, 가장 일반적인 유형이다. 웹 클라이언트가 제공하는 HTTP 쿼리 매개 변수 (예 : HTML 양식 제출)에서 적절하지 않고, 구문 분석 및 해당 사용자에게 대한 결과의 페이지를 표시하는 공격 기법이다.

검증되지 않은 사용자가 URL 파라미터나 HTTP 요청 헤더 정보를 수정하여 공격할 수 있다. 잠재적인 취약점이 존재하는 대상은 검색 엔진이다. : 검색 엔진의 검색창에서 하나의 문자열을 검색하는 경우, 검색 문자열은 일반적으로 결과 페이지에 그대로 다시 표시된다. 삽입 된 문자열을 다시 표시하면서 문자열이 가지고 있는 스크립트가 동작된다면 취약점이 존재하는 것이다.

### 지속적 (persistent) 기법 [ 편집 ]

XSS

뭐라는거지..

A 37개 언어

읽기 편집 역사 보기 도구

### 시리즈 일부 정보 보안



### 관련 보안 분류

인터넷 보안 · 자동차 보안 · 사이버 전쟁 · 컴퓨터 보안 · 모바일 보안 · 네트워크 보안

### 위협

지능형 지속 공격 · 사이버 범죄 · 취약점 · 도청 · 악성 소프트웨어 · 스파이웨어 · 랜섬웨어 · 트로이 목마 · 바이러스 · 웜 · 루트킷 · 부트킷 · 키로깅 · 스크린 스크레이퍼 · 취약점 공격 · 백도어 · 논리 폭탄 · 페이로드 · 서비스 거부 공격 · 웹 셸 · 피싱

### 방어

컴퓨터 접근 제어 · 애플리케이션 보안 (바이러스 검사 소프트웨어 · 소프트웨어 개발 보안 · 기본상 보안 · 설계상 보안 · 보안 운영 체제) · 인증 (다요소 인증) · 허가 · 데이터 중심 보안 · 암호화 · 병합 · 침입 탐지 시스템 · 모바일 보안 게이트웨이 · 런타임 응용 프로그램 자체 보호 (RASP)

V · T · E

©AUSG2023

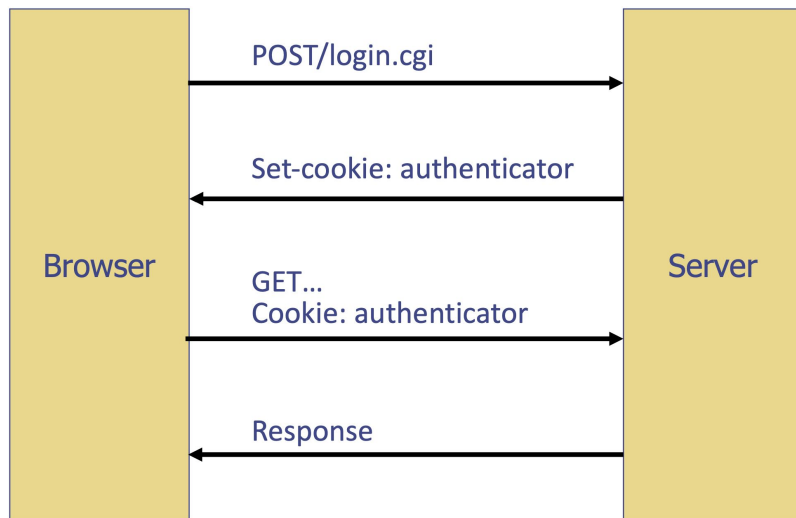
# Basic Concept



# HTTP Cookie

: 서버가 클라이언트에게 보내는 데이터 조각.

- **Session Management**  
: Logins, Shopping carts, '오늘 하루 이 팝업을 표시하지 않음'..
- **Personalization**  
: User preferences, themes, and other settings
- **Tracking**  
: Recording and analyzing user behavior

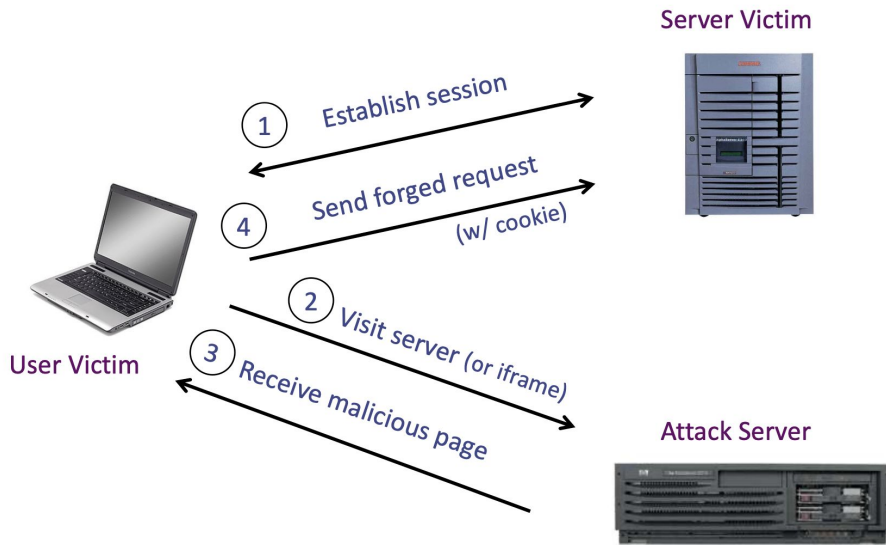


# HTTP Cookie의 취약점

- **Cookie**는 **Plaintext**, 즉 텍스트 그대로 전송된다. (물론 보완하는 방법도 있다.)
- 공격 시작점 : “만약 저 쿠키를 뺏어온다면 ...로그인 안해도 인증 되겠네?”
- 심지어, 만약 한 번 쿠키가 설정된다면 해당 도메인으로 보내는 모든 요청엔 쿠키가 함께 전송된다.

# CSRF (Cross-Site Request Forgery, 사이트 간 요청 위조)

: 사용자가 자신의 의지와는 무관하게 공격자가 의도한 행위를 특정 웹사이트에 요청하게 하는 공격



©AUSG2023

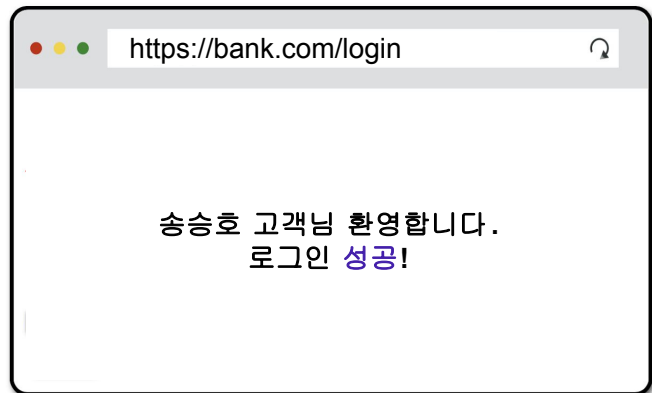


# CSRF (Cross-Site Request Forgery, 사이트 간 요청 위조)

## 공격 과정

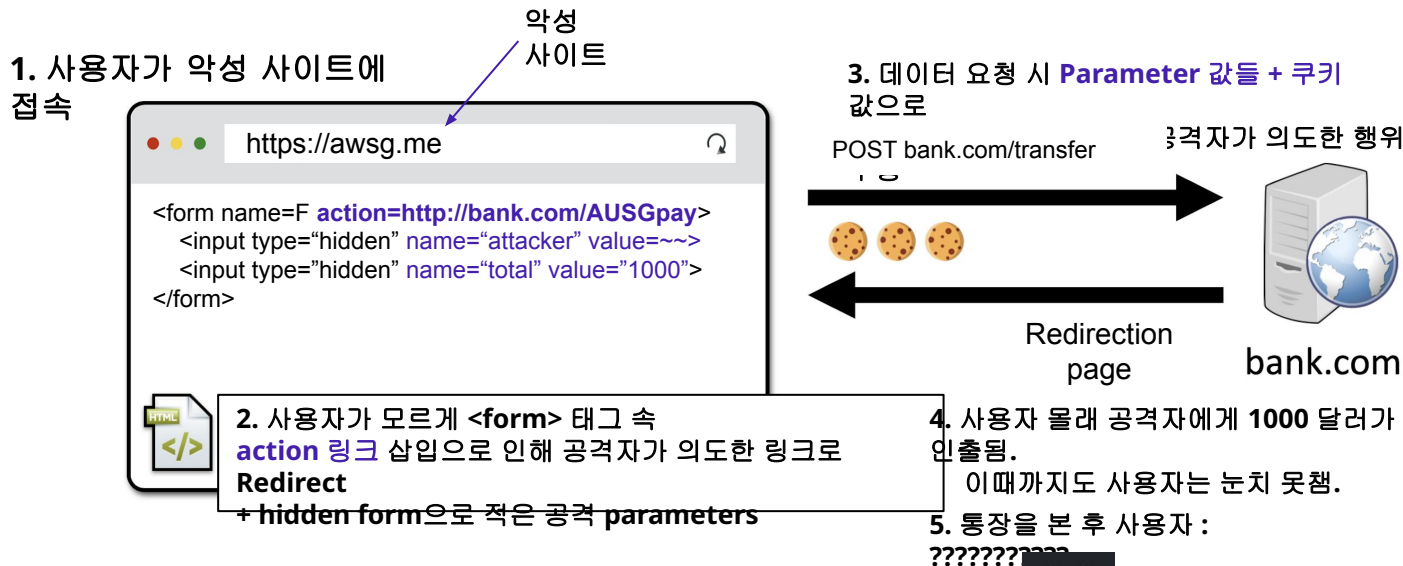
0. 사용자가 은행 사이트에 접속 및 로그인

-> 클라이언트 : 쿠키 보유 상태



# CSRF (Cross-Site Request Forgery, 사이트 간 요청 위조)

## 공격 과정



©AUSG2023



# XSS (Cross-Site Scripting, 사이트 간 스크립팅)

: 웹사이트 관리자가 아닌 이가 웹 페이지에서 악성 스크립트를 삽입 하는 공격

Malicious link

Scripting? => [http://ausg.me/search?term=<script>alert\("AUSG 다 뚫렸죠?"\)</script>](http://ausg.me/search?term=<script>alert('AUSG 다 뚫렸죠?')</script>)

```
1 <html>
2 <title>Search AUSG members</title>
3 <body>
4 <h1>Results for {term} /h1>
5 </body>
6 </html>
```

# XSS (Cross-Site Scripting, 사이트 간 스크립팅)

: 웹사이트 관리자가 아닌 이가 웹 페이지에서 악성 스크립트를 삽입 하는 공격



# XSS (Cross-Site Scripting, 사이트 간 스크립팅)

: 웹사이트 관리자가 아닌 이가 웹 페이지에서 악성 스크립트를 삽입 하는 공격

## XSS Types

- **Reflected XSS**

: Malicious Script가 단지 들어가려는 사이트의 일부분인 것처럼 보여진다 .

- **Stored XSS**

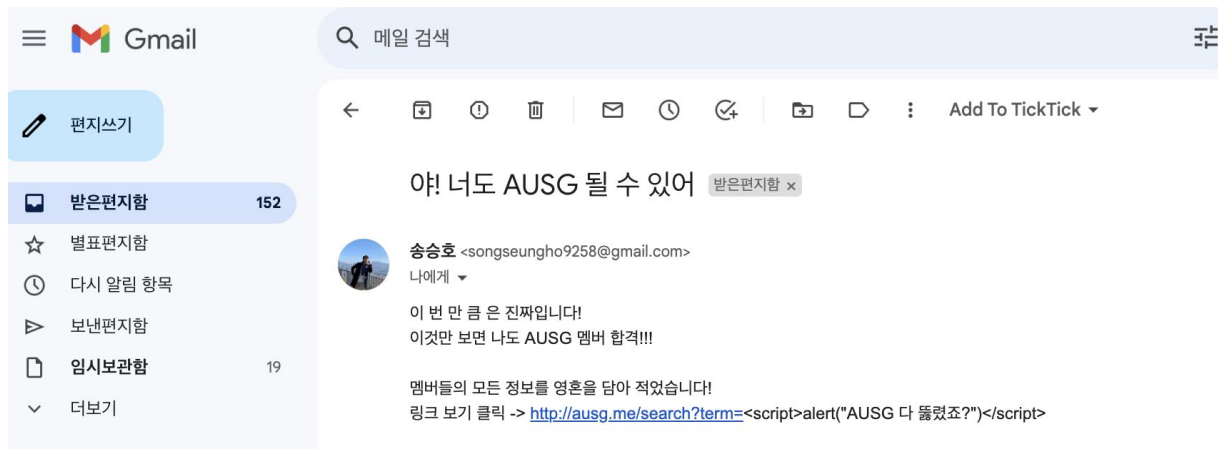
: 공격자가 미리 타겟 사이트 서버 DB에 Malicious code를 저장해놓는다 .

# XSS (Cross-Site Scripting, 사이트 간 스크립팅)

: 웹사이트 관리자가 아닌 이가 웹 페이지에서 악성 스크립트를

삽입하는 공격

사용자가 악성 사이트에 접속하게 되는 경로 in Reflected XSS



# XSS (Cross-Site Scripting, 사이트 간 스크립팅)

: 웹사이트 관리자가 아닌 이가 웹 페이지에서 악성 스크립트를

삽입하는 공격

사용자가 악성 사이트에 접속하게 되는 경로 in Stored

XSS



## Contact

궁금한게 있다면 언제든지 + 24시간 질문 받습니다.



이름 \*

송승호

이메일 \*

attack@attack.com

문의사항 \*

<script>alert("AUSG 다 댔습니다")</script>

©AUSG2023

Let's Do this



# Settings

## Bitbar

**A Node.js webapp that lets users manage Bitbars, a new ultra-safe cryptocurrency. They can transfer Bitbars to other users using the web interface, as well as create and view other user profiles.**



# Settings

## Using Firefox, not Chrome

Chrome은 보안이 너무  
철저합니다 ..



일반

홈

검색

개인 정보 및 보안

Sync

Mozilla 추가 제품 정보

확장 기능 및 테마

Firefox 도움말

설정에서 찾기

항상된 추적 방지 기능

추적기는 온라인에서 사용자를 따라다니며 탐색 습관과 관심사에 대한 정보를 수집합니다. Firefox는 이러한 많은 추적기 및 기타 악성 스크립트를 차단합니다. [더 알아보기](#)

예외 관리...

표준

보호와 성능 사이의 균형이 잡혀 있습니다. 페이지가 정상적으로 로드됩니다.

엄격

더 강력한 보호 기능을 제공하지만, 일부 사이트나 콘텐츠가 손상될 수 있습니다.

사용자 지정

차단할 추적기와 스크립트를 선택하세요.

쿠키

모든 교차 사이트 쿠키 (웹 사이트가 제대로 작동 안 할 수 있음)

추적 콘텐츠

사생활 보호 창에서만

암호화폐 채굴기

디지털 지문

주의하세요!

이 설정으로 인해 일부 웹 사이트가 콘텐츠를 표시하지 않거나 제대로 작동하지 않을 수 있습니다. 사이트가 손상된 것 같으면 해당 사이트에 대한 추적 방지 기능을 해제하여 모든 콘텐츠를 로드할 수 있습니다. [방법 알아보기](#)

Seungho Song. AUSG 7th

# Solutions

## - CSRF

- Secret Validation Token : 쿠키에 토큰을 추가하여 유효성 판단을  
강화

```
1 <form action="https://bank.com/transfer" method="post">
2 <input type="hidden" name="csrf_token" value="434ec7e838ec3167ef5">
3 <input type="text" name="to">
4 <input type="text" name="amount">
5 <button type="submit">Transfer</button>
6 </form>
```

- Referer Validation
  - Referer HTTP request header : 이전 페이지 주소 저장 (뒤로가기 클릭 시 전환이 빠른 이유)
  - http://bank.com -> http://bank.com (O)
  - http://attack.com -> http://bank.com (X)

# Solutions

## - XSS

- **Filtering malicious content** : 모든 헤더, 쿠키, query string, form ... 등을 조사하며 악성 스크립트가 있는 지 조사한다. <, >, script, ... 와 같은 문자가 들어가 있는지
- 시간이 지나면서 공격 패턴에 대한 DB가 많아졌더라도, 모든 침입을 막아내기

아래의 표는 HTML 문서에서 악성 스크립트에 포함되어 브라우저에서 실행될 수 있는 문자와 대체 문자를 정리한 것이다. 악성 스크립트는 많은 HTML 태그 안에 포함을 할 수 있으므로 반드시 아래 표에 있는 위험문자의 경우 출력값을 이스케이핑해야 한다.

| ASCII 문자 | 참조 문자 | ASCII 문자 | 참조 문자  |
|----------|-------|----------|--------|
| &        | &amp; | "        | &quot; |
| <        | &lt;  | '        | &#x27; |
| >        | &gt;  | /        | &#x2F; |
| (        | &#40; | )        | &#41;  |

[그림 13] 위험 문자 인코딩



## <세 줄 요약>

- **CSRF**는 사용자의 의지와 상관없이 쿠키를 활용하여 침입하는 기법이다.
- **XSS**는 웹페이지 내 악성 스크립트를 삽입하여 공격하는 기법이다.
- 브라우저나 보안 툴이 잘 차단해준다 한들 웹 개발 시 반드시 인지해야할 부분이다.